BACKYARD MECH | MASTER PLAN COMPARISON

Core Workflow & Security Validation Report

A source-based review of operational flow, validation coverage, security controls, and remaining gaps against the Complete System Master Plan.

REFERENCE	REVIEWED	IMPORTANT LIMIT
21 core workflows 30 security measures 42-table blueprint	**Controllers, models, services, SQL schema, project notes, and 4 smoke-test scripts**	**Source and test definitions reviewed; full database-backed suites were not run in this session.**

Executive assessment

The core staff-side repair transaction is substantially connected in code: approved estimate scope flows into a work order, labour and parts are constrained to that scope, independent QC gates invoicing, payments reconcile the invoice, and vehicle handover now requires a fully paid balance and records pickup. Exception paths also exist for estimate revisions, QC rework, payment voids/adjustments, and cancellations.

This is not a claim that every workflow is production-complete. The customer-facing portal/catalog and message delivery are absent or partial; several integrity rules live only in application code rather than SQL constraints; and operational security controls such as backup restore drills, monitoring, and tamper-resistant audit storage are not evidenced in the repository.

How to read status

Status	Interpretation
Implemented in code	Primary workflow path and meaningful server-side rules were found. Does not imply every edge case or deployment control is complete.
Partial	Core function exists, but a material master-plan flow, validation, integration, or durable constraint is incomplete.
Missing / operational	No implementation was found in the reviewed code, or it belongs to deployment/organizational operations.
Evidence note	Smoke-test scripts contain regression assertions. Since the local app at 127.0.0.1:5099 was not running, those assertions are not reported as passed in this review.

End-to-end loop snapshot

Staff/account & access -> customer/vehicle -> appointment or walk-in -> check-in -> initial inspection -> estimate/revision -> customer decision -> approved work order -> labour/parts/tools -> independent QC -> invoice -> partial/full payment -> recorded vehicle pickup -> report/audit history.

1 | Workflow Coverage

The flow table compares each master-plan core workflow with code evidence and remaining work. Test coverage means a test case exists in a repository script, not that it was executed for this report.

# / workflow	Code status	What the project currently does	Remaining gap / confidence
1. Employee account creation	Partial	Staff profile can exist without login; account is linked explicitly to a profile; role, role defaults and per-user Inherit/Allow/Deny are configurable. Smoke coverage exists.	Uses custom Users/AppRole/session architecture, not a full ASP.NET Core Identity store migration.
2. Login and permission checks	Partial	Password hashing, MFA for privileged access, lockout/rate limits, session revalidation, backend permission filter and per-user overrides. Regression assertions exist.	Monitoring suspicious activity and production multi-instance shared session/rate limiting remain.
3. Availability and booking conflicts	Implemented	Weekly shifts, exceptions, appointments, work orders, bay maintenance and mechanic/bay overlaps are checked in transactional flows. Smoke cases cover conflicts/concurrent conversion.	Validate with deployed timezone, multi-instance concurrency, and production SQL configuration.
4. Customer and vehicle registration	Partial	Staff can create/select customers and vehicles; ownership history and odometer readings are retained and checked.	No authenticated customer portal; robust duplicate-customer matching is not enforced as a unique business rule.
5. Product catalog publishing	Partial	Staff can create, edit, publish, archive and dispose product listings for parts/services.	No customer browse/request flow. Plan explicitly does not define e-commerce checkout.
6. Appointment booking	Implemented	Create/edit/cancel, walk-in/scheduled type, requested services, preferred vs assigned mechanic, and resource checks are present.	Customer confirmation/reminder delivery is not implemented.
7. Walk-in and check-in	Implemented	Customer/vehicle/odometer verification, check-in timestamp/actor, odometer history and queue history are connected.	Check-in and queue states are spread across flows; a single canonical state-transition map is still needed.

1 | Workflow Coverage: 8-14

Workflows 8-14: intake, approval and repair execution.

# / workflow	Code status	What the project currently does	Remaining gap / confidence
8. Queue and bay allocation	Partial	Queue list, bay dispatch, mechanic dispatch and conflict validation are present; changes are audited.	Finalize allowed transitions and stale/double-dispatch behavior as a published state model.
9. Initial inspection	Partial	Inspection findings and recommendations are recorded; estimate creation requires a completed inspection; media flow exists.	No structured measurements/checklist rows in current schema; duplicate inspection/reinspection rules and atomic media lifecycle need definition.
10. Estimate creation	Implemented	Revisioned estimates, server-side totals/tax, immutable historical revisions, and line-level scope/price snapshots.	Database unique constraint for EstimateId + RevisionNumber was not found.
11. Customer approval and revision	Partial	Public expiring approval link supports approval decisions and selected scope; stale/replayed links and line membership are checked.	No email/SMS delivery proof or independent customer identity; approval token is stored as a raw bearer value; changes-requested follow-up is staff-driven.
12. Work-order generation	Implemented	Only approved revision lines are usable; exact revision is linked; duplicate active work orders and scheduling conflicts are blocked.	Transition policy is not centralized across every action; approval override/escalation policy needs formal sign-off.
13. Service-time tracking	Implemented	Manual labour and timers support start/pause/resume/complete; cost and logged time are limited by approved scope; active timers block QC/billing.	SQL does not enforce non-overlapping or chronological time segments; application-level concurrency is not equivalent to a database invariant.
14. Parts receiving and inventory	Partial	Supplier and part records, receipts, reserve/install/return/waste/adjustment/reversal, ledger, and approved-quantity checks exist.	No purchase-order/delivery verification lifecycle; important ledger rules are not all expressed as SQL constraints.

1 | Workflow Coverage: 15-21

Workflows 15-21: inventory, billing, reporting and operational assurance.

# / workflow	Code status	What the project currently does	Remaining gap / confidence
15. Tool issue / return / maintenance	Partial	Availability/calibration checks, checkout, return condition, damaged-tool maintenance and maintenance completion exist.	Lost/missing-tool resolution and an explicit authorized override path for unsafe/overdue tools remain unclear.
16. Independent QC and rework	Implemented	QC requires all checklist answers; failures need notes; inspector cannot be the assigned/recording mechanic; failed jobs return to repair; reinspection supported.	Inspector identity has a name fallback for legacy records; audit and checklist policy should be reviewed for real shop identities.
17. Invoice creation	Implemented	Only QC-passed work; billable parts/labour must match approved scope; server calculates tax; invoice numbering and inserts are transactional.	App statuses (Issued, Partially Paid, Paid, Voided) differ from the plan's proposed labels; publish one canonical map.
18. Payment and adjustments	Partial	Multiple payments, positive form validation, reference requirements, replay prevention, overpayment rollback, edits/voids and adjustments exist.	Refund/reconciliation policy and payment provider integration are not implemented. Do not collect/store raw card data.
19. Reports and dashboards	Partial	Report pages and CSV/PDF/Excel exports exist; sensitive exports are audited.	Plan metrics are not fully represented; export permission granularity and formula-injection edge cases need review.
20. Audit history	Partial	Many operational, security, permission and export actions write actor/action/entity/time/details.	Audit storage is not shown to be append-only or tamper-evident; retention/monitoring policy is missing.
21. Incident response and recovery	Missing / operational	Some authentication and application errors are logged; database/data protection mechanisms exist in application code.	No in-repo incident runbook, alerting/monitoring setup, immutable evidence retention or tested backup restore procedure was found.

2 | Module Functionality Inventory

This inventory lists user-facing areas and their connected create/read/update/state-change actions. Status reflects the staff-side application path, not full plan completion or a runtime test result.

Module / code area	Actions present	How the actions connect	Main guard / remaining item
Dashboard / OwnerController	Read dashboards, counts, alerts and shortcuts.	Aggregates active appointments, work orders, estimates, inventory and billing records.	Metric definitions can differ from the master plan; not every KPI has reconciliation tests.
Staff profiles / Employees	Create, edit, view, archive, soft-delete, restore; schedule and performance views.	Profile is an employment record; it can exist without a login.	Duplicate identity matching and broader HR policy remain shop decisions.
Staff accounts / access	Create login for a selected profile; set role, active state and per-user permission overrides; inspect security log.	Role defaults plus Inherit/Allow/Deny resolve on protected requests.	Custom auth store remains; account disable/role-change flows have test assertions but need runtime execution.
Availability / schedules	Weekly shifts, create/edit/delete special availability exceptions, weekly employee schedule.	Booking/dispatch checks read shifts, absences, appointments, work orders and bay maintenance.	Timezone/host configuration and SQL-backed concurrency need environment verification.
Settings / roles and permissions	Create, edit, delete roles; configure module/action defaults; save permissions.	Permission service controls sidebar visibility and backend actions; user overrides do not mutate role defaults.	Review protected-role lifecycle, unique role-permission DB constraint and a final approved permission matrix.

2 | Module Functionality: Customers and Intake

Customer, vehicle, appointment, queue and inspection.

Module / code area	Actions present	How the actions connect	Main guard / remaining item
Master data / suppliers	Supplier create/update/activate/deactivate; service/category/tax CRUD; separate parent/child categories.	Supplier and categories feed part/tool/service forms; tax date feeds estimates/invoices.	No purchase order or supplier delivery-document workflow; deactivate is the history-preserving alternative to delete.
Customer records	Create/edit/search/view details, vehicles and service history.	Customer snapshots link appointments, estimates, invoices and vehicle ownership.	No server duplicate-customer guard; customer self-service portal is absent.
Vehicles / ownership	Register vehicle; transfer owner; record/view odometer and ownership history.	Current ownership is validated for intake; historical owner names remain on records.	External authority verification is not integrated; unit is inherited from existing shop policy.
Appointments / check-in	Create/edit/cancel appointment; scheduled or walk-in; check in; record requested services.	Validated booking proceeds to intake queue; check-in stamps staff/time, odometer and history.	No reminder/confirmation delivery; canonical appointment status map is not centralized.
Service queue / bay dispatch	View queue/detail; update queue status; assign bay and mechanic.	Dispatch then opens inspection/work order and prevents conflicting resource use.	Transition map and duplicate/stale dispatch edge cases need explicit tests.

2 | Module Functionality: Repair and Inventory

Approval, work order, labour, parts, QC and tools.

Module / code area	Actions present	How the actions connect	Main guard / remaining item
Initial inspection / media	Save inspection findings/recommendation; add and view authorized photos.	A completed initial inspection is a prerequisite for estimate creation.	No structured measurements; duplicate/reinspection policy, atomic media cleanup and malware scan remain.
Estimates / customer approval	Create and revise line items; send approval link; record all/partial/decline/change decision; cancel.	Only exact approved revision lines can become repair scope; old revisions remain history.	Raw bearer token and missing delivery/recipient proof; DB revision-number uniqueness is absent.
Work orders / assignment	Generate/edit/cancel/reopen; assign bay/lead/helper; transition repair/QC; status page; release vehicle.	Approved estimate -> repair -> QC -> invoice -> paid pickup; release stores actor/time and closes appointment.	Status rules are distributed among actions; run full integration suite and confirm migration on installed DB.
Labour and time tracking	Add/edit/delete labour; start/pause/resume/complete timers; view history/costs.	Entry description/rate/hours derive from an approved estimate line; completed duration bills to invoice.	DB does not enforce segment ordering/overlap; corrections and concurrent timer edge cases need more tests.
Parts inventory / spares allocation	Part CRUD/archive/dispose; receive/reserve/install/return/waste/adjust/reverse; view audit.	Work-order quantities and prices reconcile with approved estimate; stock movements update available balance.	No supplier delivery verification; some ledger invariants remain application-only.

2 | Module Functionality: Billing and Governance

Invoice, payment, records disposition, reports and audit.

Module / code area	Actions present	How the actions connect	Main guard / remaining item
Product listings	Create/edit/archive/dispose/publish listing for exactly one part or service; set title/description/price/order.	Staff-facing listing directory is separate from inventory; no cart/checkout is specified.	SQL allows both linked IDs to be null and does not align ListingType with source; DB CHECK should be tightened.
Quality control	Execute six-check inspection; record pass/fail and reasons; view result; void latest result/reinspect.	Fail returns repair to In Repair; pass moves to Ready for Pickup and gates invoice generation.	Inspector name fallback for legacy rows; checklist and allowed reinspection policy need sign-off.
Tool tracking	Tool CRUD/archive/dispose; checkout/return; damage and calibration checks; maintenance create/complete; history.	Unsafe/damaged returns route to maintenance before a new checkout.	Lost-tool resolution and authorized override for unsafe/overdue tools are not fully specified.
Invoices and payments	Generate/view/void invoice; add/edit/void payment; add/edit/void credit/debit adjustment; print/export.	Actual approved work is snapshotted; partial payments recalculate balance; fully paid invoice permits release.	Refund/reconciliation policy, final status vocabulary and DB positive amount rule need alignment.
Records disposition / archive	Set retention; view/restore; delete archived item to disposition; permanently delete eligible disposed records.	Soft-delete retention clock, archive restoration and scheduled permanent purge preserve historical handling.	Retention coverage differs by record type; legal schedule, dependency behavior and purge audit need final review.

3 | Transaction Loop and Branches

Primary repair-to-release loop

Stage	Expected guard	Assessment
Inspection -> estimate	Inspection must be complete; totals are calculated on server.	Present; estimate create path is blocked without inspection.
Estimate -> approval	Only current revision and valid unexpired link; decision limited to revision lines.	Present; token delivery/customer identity remain gaps.
Approval -> work order	Work order references exact approved revision; declined scope cannot be billed/executed.	Present in code and covered by repair smoke assertions.
Repair -> labour/parts	Resource/time/stock and line price/hour limits apply against approved scope.	Present; strongest workflow lock is app-level; DB constraints are incomplete.
Repair -> QC	Repair is completed, timers stopped; independent inspector evaluates checklist.	Present; fail route returns job to repair.
QC pass -> invoice	Passed QC and billable actual usage required; invoice number and rows commit together.	Present; invoice status vocabulary needs standardization.
Invoice -> paid	Partial payments update balance; payment cannot exceed outstanding amount.	Present; full-paid path is included in smoke script, not executed in this audit.
Paid -> customer pickup	Requires confirmed handover, Paid invoice and zero balance; stores timestamp, staff, appointment completion and audit.	Implemented recently; script asserts blocked unpaid/partial release and successful full-paid release.
Pickup -> final record	Work order becomes Picked Up; release cannot be repeated.	Implemented; regression assertions exist, runtime not yet observed here.

Exception loops present

- Estimate: draft/revision -> customer approves all or selected lines, declines, or requests changes; stale approval links are rejected. Staff must create/re-send a follow-up revision where needed.
- QC: fail -> In Repair -> work correction -> Pending QC -> repeat check; failed check cannot issue an invoice.
- Payments: partial balance remains open -> additional payment -> Paid at exact balance; void/credit adjustment retains an audit trail.
- Cancellation: work order cancellation requires labour/installed parts/reservations to be resolved; invoice void/payment void remain explicit history-preserving operations.

Overall loop verdict

The intended staff-side transaction now has a defined terminal pickup step. The source contains checks and a new successful full-payment/release scenario in the repair smoke script. However, because the server/database smoke suite was not run during this report, call this **implemented with an unexecuted integration scenario**, not a runtime-proven end-to-end success.

4 | Validation Present in Code

The following checks were found in application actions, services, form models, or SQL. Their presence does not imply every boundary is covered or that every rule is enforced by the database.

Area	Checks currently present
Authentication	Password hashing; persistent failed-attempt lockout; login/MFA request rate limiting; privileged MFA; OTP replay rejection; one-use recovery codes; active account/role/password state revalidated on protected requests; idle/absolute session expiry.
Authorization	Module/action permission filter on server actions; per-user Allow/Deny/Inherit overrides; hidden modules also deny direct access; role permissions and sensitive changes audited.
Request safety	Antiforgery validation on mutations; model binding/required/range checks on forms; parameterized EF queries for data access; SQL lock strings are fixed constants.
Scheduling	Appointment/work-order/bay/mechanic overlap checks; shift and availability exception checks; bay maintenance checks; serializable shared workflow lock; shift changes revalidate bookings.
Customer/vehicle	Ownership snapshots and transfer reason; open work blocks transfer; vehicle identity constraints; odometer nonnegative and nondecreasing; check-in requires verified appointment/customer/vehicle and reading.
Master data	Duplicate supplier/service/category checks; parent-child category cycle/active-parent checks; active-reference checks; tax effective date and overlap checks; optimistic stamps on selected edits.
Estimate / scope	Current revision and expiry checks; decision values/line IDs validated; work order links approved revision; actual parts/labour derive descriptions/rates from approved rows; quantity/hour caps are rechecked at billing.
Inventory / labour	Reservation before install/waste; prevent negative stock, oversell and reversal of dependent movements; single active timer per mechanic; timer completion and approved-hours caps; open timer blocks QC/billing.
QC / invoice / payment	QC answers required; failure reason required; inspector separation; QC pass gates invoice; duplicate invoice blocked; transactional number counter; payment date/method/reference checks; duplicate submission and overpayment rejected.
Pickup / audit	Release requires explicit confirmation, exact Ready for Pickup state, active Paid invoice and payment sum equal to invoice total; duplicate release blocked; pickup actor/time and audit event recorded.
Uploads / records	Inspection upload size/type/signature validation and permission-protected viewing; automatic disposition worker for supported record classes; archive/restore and permanent delete paths are present.

Database enforcement snapshot

- SQL schema includes many foreign keys, unique indexes for key identifiers, and nonnegative checks for monetary values, stock and odometer fields.
- Several business invariants are still code-only: examples include exact ProductListing source/type agreement, positive payment amount at the database layer, unique estimate revision numbers, unique role-permission pairs, and time-segment ordering/overlap.
- Application-level transactions and sp_getapplock reduce races in selected flows but do not replace SQL constraints or shared distributed locks across multiple app instances.

5 | Security Cross-Check: 1-15

Each numbered row maps to an individual master-plan security measure. Status describes evidence in the reviewed source, not a penetration-test result or a production deployment certification.

# / plan measure	Evidence found in project	Status / remaining work
1. Identity and password storage	Custom Users/AppRole/session auth; salted password hashes and hash upgrade path.	PARTIAL: migrate to full ASP.NET Core Identity stores and managers as planned.
2. Multi-factor authentication	Privileged MFA, OTP replay rejection and one-use recovery codes; smoke assertions exist.	PARTIAL: verify recovery governance, enrollment lifecycle and runtime coverage.
3. Login abuse protection	Persistent failed-attempt lockout and login/MFA request rate limiting.	PARTIAL: suspicious-login monitoring and distributed rate limiting across app instances are absent.
4. Authorization and record scope	Server-side module/action permission filter; role defaults and per-user overrides.	PARTIAL: customer portal and owner-scoped cross-customer isolation are not implemented.
5. HTTPS and transport security	HTTPS redirection/HSTS and secure cookie configuration are present in startup.	DEPLOYMENT: confirm reverse-proxy headers, TLS policy and production host configuration.
6. CSRF protection	Antiforgery validation on state-changing actions and corresponding smoke assertions.	PARTIAL: verify every mutation route and exception path; run the suite against the deployed pipeline.
7. XSS and browser policy	Razor output encoding is the baseline for rendered user data.	PARTIAL: no explicit Content Security Policy found; review raw HTML/JS sinks and CSP rollout.
8. SQL injection	EF query paths are parameterized; fixed SQL lock identifiers are constants.	PARTIAL: audit all raw SQL/string-built predicates and keep dynamic identifiers allow-listed.
9. Input validation	Form/model checks and business-rule validation cover dates, amounts, state and scope in key flows.	PARTIAL: several invariants remain application-only or lack executed regression evidence.
10. Upload validation	Inspection upload size/type/content-signature checks are present.	PARTIAL: add malware scanning, adversarial file tests, safe filenames and robust failure cleanup.
11. Private media access	Media viewing is permission-gated instead of directly exposing protected inspection files.	PARTIAL: verify storage ACLs, orphan cleanup, backup/restore and authorization for every media route.
12. Customer approval tokens	High-entropy expiring approval links, revision checks and replay rejection exist.	PARTIAL: raw token storage; add hashed tokens, revoke/resend, recipient verification and delivery evidence.
13. Data at rest	Application Data Protection protects authenticator secrets.	DEPLOYMENT: verify SQL files, backups and media encryption at rest for the target environment.
14. Secret and key management	Connection/configuration settings are external to source; Data Protection is used for secrets.	DEPLOYMENT: production secret store and durable shared key-ring/rotation procedure remain operational tasks.
15. Audit events	Sensitive operations record actor, action, entity, time and details; selected tests assert audit writes.	PARTIAL: establish coverage matrix, retention, review ownership and alerting for critical events.

5 | Security Cross-Check: 16-30

The second half covers audit integrity, operational resilience, privacy, financial safeguards and security assurance.

# / plan measure	Evidence found in project	Status / remaining work
16. Audit integrity and monitoring	Operational audit rows exist for many repair, permission and export actions.	PARTIAL: no append-only/tamper-evident archive or complete monitoring/retention policy found.
17. Concurrency integrity	Transactions and SQL application locks protect selected scheduling, stock, numbering and payment paths.	PARTIAL: SQL-instance scoped locks do not prove cross-instance safety; run race tests in deployment topology.
18. Least-privilege database access	Application uses SQL access through configured connection settings.	MISSING EVIDENCE: restricted production SQL login/grants and deployment proof are not packaged.
19. Backup and recovery	No complete backup-and-restore operational evidence identified in reviewed docs.	MISSING: encrypted schedule, retention, restore drills, recovery objectives and assigned owners.
20. Security monitoring and incident response	Some authentication/application events are logged.	MISSING: actionable alerts, incident runbook, evidence preservation and tested recovery process.
21. Payment security	No card-entry flow or raw card-data storage found.	N/A currently: keep card data out of the app; use a compliant payment provider if introduced.
22. Privacy and records retention	Archive/disposition workflows and retention configuration exist for supported record classes.	PARTIAL: confirm legal/DPA basis, full data-class schedule, exceptions and proof of purge.
23. Dependency security	Dependencies are versioned in project manifests.	MISSING: documented automated vulnerability scanning, patch SLAs and release review evidence.
24. Security testing	Four database-backed smoke scripts exercise selected authorization and abuse scenarios.	PARTIAL: not a complete ASVS/penetration assessment; suites were not executed for this report.
25. Export security	CSV/PDF/Excel exports and export audit paths exist.	PARTIAL: test whitespace/control-character formula prefixes and report-specific permission/scope boundaries.
26. Financial integrity	Approved-scope billing, transactional invoice numbering, payment/adjustment/void paths and audit exist.	PARTIAL: finalize refund/reconciliation policy, SQL positive-value constraints and immutable financial history.
27. Service-time integrity	Timer flow supports start/pause/resume/complete and excludes pauses from billable duration.	PARTIAL: DB does not enforce valid ordering/non-overlap; add concurrency, correction and reconciliation tests.
28. Independent quality control	QC requires checklist answers and checks separation from the assigned mechanic.	PARTIAL: legacy name fallback and inspector identity policy need review; test every reassignment/reinspection path.
29. Customer-data isolation	No authenticated customer portal was found in the reviewed application.	NOT IMPLEMENTED: before portal release, enforce owner-scoped access and IDOR tests for every customer resource.
30. Incident preparedness	No incident-response runbook found in the reviewed docs.	MISSING: contacts, severity, triage, containment, evidence handling, recovery and post-incident review.

6 | Master-Plan Data Model: 1-14

The master plan specifies 42 business tables. All 42 planned table names were found in Database/BackyardMech_BusinessSchema.sql. This matrix checks planned data coverage; it does not claim every listed column, relationship or invariant has been verified against production data.

# / entity	Purpose in the planned flow	Coverage note
1. EmployeeProfile	Staff identity and employment profile, separate from login.	Schema present; account/profile distinction and employee management actions are inventoried above.
2. EmployeeRateHistory	Effective-dated hourly-rate history and actor.	Schema present; verify rate-change audit and historical invoice snapshots.
3. EmployeeAvailability	Weekly regular working hours.	Schema present; availability is checked in booking/dispatch code.
4. EmployeeAvailabilityException	Date/time-specific absence or availability override.	Schema present; CRUD and booking checks have smoke-test definitions, not a runtime result here.
5. Permission	Module/action permission catalog.	Schema present; keep permission codes canonical and protect role/permission administration.
6. RolePermission	Role defaults per permission.	Schema present; add/verify a unique (RoleId, PermissionId) database constraint.
7. AuditLogEntry	Actor, action, entity, timestamp and details.	Schema present; append-only/tamper-evident storage and retention are outstanding.
8. Customer	Customer contact and address details.	Schema present; no duplicate-customer server guard was identified; no customer portal.
9. Vehicle	VIN, plate, make/model/year, color and current odometer.	Schema present; intake validates identity/odometer; retain history on account/customer deletion.
10. VehicleOwnership	Current and historical vehicle owner snapshots.	Schema present; transfer and ownership-history behavior are inventoried above.
11. VehicleOdometerHistory	Timestamped odometer readings and recorder.	Schema present; nondecreasing reading is app-validated; SQL enforcement/concurrency should be reviewed.
12. Bay	Shop work-bay identity and active state.	Schema present; bay maintenance and dispatch conflicts are included in operational checks.
13. Appointment	Booking, customer/vehicle, schedule, assignment, check-in and status.	Schema present; canonical status transitions and concurrent booking behavior need final proof.
14. AppointmentService	Services requested for an appointment.	Schema present; verify service snapshot and changes stay aligned through estimate revisions.

6 | Master-Plan Data Model: 15-28

Queue, intake, catalog, inventory, estimate approval and work authorization.

# / entity	Purpose in the planned flow	Coverage note
15. QueueStatusHistory	Appointment queue transitions, actor, time and notes.	Schema present; audit all transition routes and reject invalid state changes.
16. Inspection	Initial intake inspection and findings.	Schema present; structured checklist/measurement table is not in the 42-table plan.
17. InspectionMedia	Inspection image/video reference and uploader.	Schema present; private media path exists; malware scan and atomic cleanup remain.
18. Supplier	Supplier identity, contact and account details.	Schema present; supplier CRUD exists; purchase-order and delivery-document flow is not implemented.
19. PartCategory	Part parent/child categories.	Schema present; parent-child cycle and active-parent checks exist; review DB self-reference constraints.
20. Part	SKU, supplier/category, prices, stock and reorder threshold.	Schema present; CRUD and stock movements exist; reconcile SQL quantity and ledger invariants.
21. PartTransaction	Receipt/reserve/install/return/waste/adjust history.	Schema present; transactional stock flow exists; supplier receipt proof and ledger reconciliation need coverage.
22. ServiceCategory	Service parent/child categories.	Schema present; category hierarchy CRUD exists; review DB self-reference constraints.
23. Service	Service name, default price and estimated time.	Schema present; service catalog CRUD feeds appointment/estimate forms.
24. Estimate	Stable estimate parent associated with appointment.	Schema present; estimate create/revise/approval path is in the workflow inventory.
25. EstimateRevision	Immutable version, approval token, totals and decision state.	Schema present; add/verify unique (EstimateId, RevisionNumber); token hashing/revocation remain.
26. EstimateRevisionLineItem	Part/service scope, quantity, rate and approval.	Schema present; approved-line scope is checked before repair/billing; validate DB source/type invariants.
27. WorkOrder	Authorized repair instance, schedule, bay and status.	Schema present; exact approved revision is linked; centralize allowed status transitions.
28. WorkOrderAssignment	Mechanic/helper role assignments and assignment time.	Schema present; mechanic/lead/helper dispatch exists; audit reassignment and concurrency cases.

6 | Master-Plan Data Model: 29-42

Actual work, tool custody, quality, tax, invoicing, payments and customer-facing listing records.

# / entity	Purpose in the planned flow	Coverage note
29. ServiceEntry	Performed service, mechanic, hours, rate and cost.	Schema present; labor CRUD/timers and approved-scope billing exist; snapshot consistency needs tests.
30. ServiceTimeSegment	Start/end intervals and work/pause classification.	Schema present; timer flow exists; DB lacks complete ordering/overlap enforcement.
31. ToolCategory	Tool parent/child categories.	Schema present; category hierarchy is represented; verify same cycle/active-parent policy as other categories.
32. Tool	Tool serial, location, condition, calibration and active state.	Schema present; tool CRUD/archive/disposition and calibration checks exist.
33. ToolCheckout	Work-order custody, mechanic, time and checkout/return condition.	Schema present; issue/return paths exist; lost-tool resolution and override policy remain.
34. ToolMaintenance	Maintenance performed, next due, cost, mechanic and notes.	Schema present; maintenance create/complete exists; verify overdue/damaged state transitions.
35. QualityCheck	Inspector, pass/fail, timestamp and notes.	Schema present; independent QC and rework loop exist; legacy inspector-name fallback needs policy review.
36. TaxRate	Rate and effective date range.	Schema present; CRUD and effective-date overlap checks exist; verify boundary-date behavior.
37. Invoice	Issued invoice, customer snapshot, tax and totals/status.	Schema present; QC and approved scope gate invoice generation; standardize status vocabulary.
38. InvoiceLineItem	Charge snapshot with source, quantity, rate and total.	Schema present; invoice lines are generated from actual approved work; reconcile rounding/tax rules.
39. InvoiceAdjustment	Credit/debit correction, reason, actor and time.	Schema present; adjustment paths exist; refund/reconciliation policy remains to be signed off.
40. Payment	Receipt amount, method, reference, date and receiver.	Schema present; partial/full payment flow exists; add SQL positive-amount constraint and reconciliation tests.
41. InvoiceNumberCounter	Transactional invoice-number allocation.	Schema present; allocation is transactional; test rollback, parallel allocation and voided-number policy.
42. ProductListing	Staff-managed part/service listing and publication fields.	Schema present; CRUD is separate from inventory; SQL should require exactly one matching source.

7 | Remaining Validation Gaps

Prioritized follow-up work. Security and business rules should be enforced server-side first, then in SQL where durable invariants can be expressed.

Priority	Gap	Suggested validation / evidence
HIGH	Customer identity and portal isolation	Before a customer portal is released: authorize every record by authenticated customer/ownership, test changed IDs for estimates/vehicles/invoices/media, and add duplicate-customer matching policy.
HIGH	Estimate approval token handling	Store a hash instead of raw token; provide revoke/resend lifecycle; record delivery result and recipient; verify customer before exposing financial/vehicle data.
HIGH	Initial inspection lifecycle and media	Define duplicate/reinspection rules; add structured measurements if required; stage media writes, rollback metadata failures, remove orphan files, malware scan and test unauthorized downloads.
HIGH	Product listing database invariant	Change SQL CHECK to require exactly one PartId or ServiceId, and ensure ListingType matches that source. Test each invalid/null/mismatched permutation directly against SQL.
HIGH	Concurrency across app instances	Run simultaneous booking, stock reservation, invoice-number and payment requests against the deployed topology; use a distributed coordination strategy if instances do not share one SQL lock scope.
MEDIUM	Missing unique constraints	Consider unique (EstimateId, RevisionNumber) and (RoleId, PermissionId); check existing duplicate data and deployment migration before adding constraints.
MEDIUM	Amount and quantity positivity at database layer	Payment.Amount currently permits zero in SQL; estimate line quantity also permits zero. Add conditional checks matching business semantics and preserve legitimate zero-hour/credit cases.
MEDIUM	Service time segments	Reject end <= start, duplicate open segments, overlapping work segments, and invalid work/pause ordering; include concurrency tests and auditable corrections.
MEDIUM	State transition matrix	Publish canonical Appointment/WorkOrder/Invoice status enums, allowed transitions, terminal states and reopen/void rules; reject unknown values consistently in UI, controller and DB.
MEDIUM	Supplier receiving lifecycle	Add delivery/source-document verification and supplier attribution to receipts if required by the master plan's supplier-to-stock traceability.
MEDIUM	Tool exceptions and loss	Define audited lost/missing recovery/write-off and authorized unsafe/overdue override policy; test checkout rejection, override permission and final resolution.
MEDIUM	Report export scope and formula safety	Separate sensitive export grant where needed; validate report-specific filters/row scopes; neutralize leading whitespace/control chars before =,+,-,@ and regression-test CSV/Excel output.
OPS	Backups, keys, monitoring, incident readiness	Set least-privilege SQL account; persist/share Data Protection keys; encrypt backups; perform restore drills; configure alerting and document response/retention owners.
OPS	Security assurance	Run all smoke suites on a clean development database, then perform threat modeling, dependency scan and scoped penetration/ASVS review before production.

Recommended implementation order

- 1. Close customer-data exposure and approval-token risks before opening any customer portal.
- 2. Add the exact database invariants and state-transition matrix; include migration preflight checks for existing rows.
- 3. Test concurrency and the entire estimate-to-paid-pickup loop on a clean development database, including rollback and repeat submissions.
- 4. Complete upload lifecycle, export edge cases, tool-loss policy, and supplier receipt traceability.
- 5. Finish production hardening: credentials, HTTPS/key persistence, encrypted backups/restore, alerting, audit retention and incident runbook.

8 | Test Evidence and Review Limits

Regression scripts located in the repository

Script	Scope indicated by source	Run status for this report
RepairWorkflow.Smoke.ps1	Estimate, approval, exact approved scope, scheduling, stock, labour/timers, QC, invoice, payment/adjustment, full payment and pickup, authorization/MFA/CSRF.	PowerShell syntax checked. Not executed; app port 5099 was not listening.
VehicleIntake.Smoke.ps1	Vehicle/customer relationship, ownership, odometer, appointment and check-in rules.	Source reviewed; not executed.
StaffAccess.Smoke.ps1	Profile/account separation, role defaults, user overrides, session refresh and availability exceptions.	Source reviewed; not executed.
MasterData.Smoke.ps1	Supplier, categories, services and tax CRUD, hierarchy/effective-date validation, permissions and CSRF.	Source reviewed; not executed.

The repository has approximately 200 explicit Check assertions across these scripts (count can change as scripts evolve). These checks are coverage intent only until executed. RepairWorkflow.Smoke.ps1 deliberately uses SQL Server and an authenticated running app, so it must run only against a development database.

Review methods and sources

- Primary plan: docs/BackyardMech_Complete_System_Master_Plan.pdf, pages 1-10 for modules, core workflows and security; pages 11-16 for the proposed 42-table design.
- Code: Controllers, Models, Services, Data/ApplicationDbContext.cs, Database/BackyardMech_BusinessSchema.sql, views and startup schema setup.
- Project notes: Docs/Security-Hardening.md, Docs/Vehicle-Intake.md, Docs/Staff-Accounts-And-Availability.md, Docs/Master-Data.md and tests/RepairWorkflow.md.
- Time basis: source snapshot reviewed on 2026-11-02. This report does not claim live execution of SQL-backed smoke suites.

Bottom line

The main staff transaction now has a coded path from approved scope through QC, invoice settlement and recorded customer pickup, with meaningful business validations and a defined full-payment smoke scenario. The highest remaining risks are not missing CRUD screens: they are customer portal/token protection, database-level invariants, cross-instance concurrency proof, inspection/media lifecycle, export edge cases, and production monitoring/backup/audit operations.

This report is an engineering comparison, not legal, privacy, financial, or security certification. Confirm shop policy and deployment assumptions before treating any pending master-plan item as complete.